

 BIBLIOTECA NACIONAL PEDRO HENRÍQUEZ UREÑA REPÚBLICA DOMINICANA	BIBLIOTECA NACIONAL PEDRO HENRÍQUEZ UREÑA	DPyD Versión 1
	MANUAL DE POLÍTICAS Y PROCEDIMIENTOS	

NOMBRE DEL PROCESO: Metodología y Gestión de Riesgos de Ciberseguridad		
Preparado por: Departamento de TIC	Aprobado por: Dirección Nacional	Código/Páginas: BNPHU-TIC-005
1.0 Propósito o Misión: Definir un enfoque estructurado para identificar, analizar, evaluar y tratar los riesgos tecnológicos, garantizando que estén bajo umbrales aceptables para la BNPHU.		
2.0 Alcance: Empieza: Inventariado de activos y definición de la metodología de evaluación. Incluye: Identificación de amenazas, cálculo de probabilidad e impacto, determinación de riesgo inherente, aplicación de controles y monitoreo del riesgo residual. Termina: Documento de aceptación del riesgo por la MAE y mejora continua.		
3.0 Dueño o responsables: 3.1 Oficial de Seguridad (CISO) / Dpto. TIC 3.2 Dirección Nacional (MAE)		
4.0 Documentos de referencia: 4.1 NORTIC A7:2016 (Capítulo V) 4.2 NIST CSF v2.0 (Identify - Risk Assessment ID.RA) 4.3 ISO/IEC 27005 (Guía)		
5.0 Políticas del Procedimiento: 5.1 Metodología de Riesgo: Se basa en cálculos cuantitativos y cualitativos, alineada al plan estratégico del organismo. 5.2 Cálculo: Riesgo (R) = Impacto (I) x Probabilidad (P). Utilizando una escala del 1 al 4, generando riesgos de 1 a 16. 5.3 Niveles de Riesgo: 1 a 6 (Bajo), 8 a 9 (Medio), 12 a 16 (Alto). 5.4 Tratamiento: Todo riesgo debe someterse a acciones de mitigación, transferencia, anulación o aceptación. 5.5 Aceptación: Todo riesgo residual requiere firma de la máxima autoridad confirmando que asume la responsabilidad operacional.		
6.0 Descripción de las Actividades del Proceso:		
Responsable	Descripción	
CISO / Dpto. TIC	6.1 Realiza el levantamiento periódico de activos y amenazas (virus, desastres naturales, fallas de hardware, robo).	
CISO / Dpto. TIC	6.2 Aplica la fórmula (I x P) y elabora la Tabla de Apreciación de Riesgos.	
CISO / Dpto. TIC	6.3 Propone controles tecnológicos y administrativos (Firewalls, UPS, Políticas) para crear el Plan de Acción de Tratamiento.	
Dirección Nacional	6.4 Analiza el costo-beneficio de los controles propuestos y aprueba el presupuesto y el nivel de riesgo residual.	
CISO / Dpto. TIC	6.5 Monitorea los indicadores continuamente y presenta reportes anuales de la evolución de la matriz de riesgos.	

7.0 ANEXOS:					
7.1 Tablas de Apreciación de Riesgos					
7.2 Plan de Tratamiento de Riesgos					
7.3 Acta de Aceptación de Riesgo Residual					
8.0 REGISTROS:					
CODIGO	NOMBRE	ALMACENAMIENTO	ARCHIVADO	TIEMPO	DISPOSICION
9.0 Historia de Cambio:					
REVISIONES	FECHAS	SECCION	DESCRIPCION	REVISADO POR	REFRENDADO POR
10.0 TIEMPO DE RESPUESTA: Evaluación anual o al existir cambios estructurales.					
FIN DEL PROCEDIMIENTO					